UNIVERSIDAD DE SAN BUENAVENTURA
Tecnología en Desarrollo de Software · VI semestre
Programación Avanzada y Aplicada

Informe de seguridad y vulnerabilidades

Credenciales, dependencias, comunicaciones y privacidad

Proyecto final: **AsistenteIA**, asistente académico móvil con .NET MAUI y una API REST de IA

Autor: Jeferson Wilderman González Tenjo y equipo
Docente: Mg. Sandra Esperanza Sánchez Barragán
Fecha de ejecución: 16 de octubre de 2026
Versión evaluada: rama `feat/rediseno-interfaz` (commit 6a15fc1)

1. Introducción

Este informe documenta las verificaciones de seguridad de AsistenteIA. Responde al principio técnico de la guía: la aplicación móvil no debe incluir claves secretas en el código, en archivos de configuración ni en el repositorio, y la clave ingresada por el usuario debe guardarse con SecureStorage.

2. Objetivo

Comprobar que la clave de la API está protegida, que el repositorio no expone credenciales ni binarios, que las dependencias no tienen vulnerabilidades conocidas y que las comunicaciones usan solo HTTPS.

3. Alcance

- Revisión de dependencias NuGet (S01, S02).
- Búsqueda de claves en todo el repositorio (S03).
- Exclusión de bin y obj (S04).
- Uso exclusivo de HTTPS (S05).
- Protección de la clave en la interfaz y en el almacenamiento (S06, P04, A04).

4. Entorno y metodología

Elemento	Detalle
Sistema operativo	Windows 11 Pro (destino Windows Machine, .NET MAUI con WinUI)
Plataforma	.NET 10, .NET MAUI, CommunityToolkit.Mvvm 8.4, sqlite-net-pcl 1.11
Proveedor de IA	Google Gemini, modelo gemini-3.8-flash (API compatible con Chat Completions)
Tamaños de ventana	1100×820 (normal), 400×800 (móvil), 820×860 (tablet), 1400×860 (escritorio)
Automatización	UI Automation de Windows (pywinauto) usando el AutomationId de cada control; una captura por paso
Datos	Respaldo previo de historial, preferencias y clave cifrada; restauración al terminar
Privacidad	La clave real aparece tapada en las capturas; los contactos del sistema, difuminados

Cada caso se ejecutó sobre la aplicación compilada en modo Debug, navegando por la interfaz igual que un usuario: selección de pestañas, escritura en los campos, pulsación de botones y confirmación de diálogos. El resultado obtenido se tomó del texto real que mostró la aplicación (mensaje de estado, resumen del historial o etiquetas), no de suposiciones.

5. Resultados

Caso	Verificación	Resultado	Estado
S01	dotnet list package --vulnerable --include-transitive	Ningún paquete con vulnerabilidades conocidas	**Aprobado**
S02	dotnet list package --deprecated	Ningún paquete obsoleto	**Aprobado**
S03	git grep de patrones sk_, pk_, AIza y Bearer	Ninguna clave real en el repositorio	**Aprobado**
S04	git ls-files y git check-ignore	bin/ y obj/ excluidos por .gitignore	**Aprobado**
S05	URL de los servicios	Solo HTTPS	**Aprobado**

Caso	Verificación	Resultado	Estado
S06	SecureStorage, IsPassword y registros	Clave cifrada, campo oculto y nunca escrita en consola	**Aprobado**
P04	Clave inválida	401 sin mostrar la clave (solo los 4 últimos caracteres)	**Aprobado**
A04	Eliminar clave	Con confirmación; se borra del almacenamiento seguro	**Aprobado**

Seguridad · Paquetes NuGet con vulnerabilidades conocidas

```
$ dotnet list package --vulnerable --include-transitive

  Determinando los proyectos que se van a restaurar...
  Todos los proyectos están actualizados para la restauración.

Se han usado los orígenes siguientes:
   https://api.nuget.org/v3/index.json
   C:\Program Files (x86)\Microsoft SDKs\NuGetPackages\

El proyecto "AsistenteIA" especificado no tiene paquetes vulnerables en los orígenes actuales.

Resultado: APROBADO
```

Figura 1. S01: sin paquetes vulnerables (incluye dependencias transitivas).

Calidad · Paquetes NuGet obsoletos (deprecated)

```
$ dotnet list package --deprecated

  Determinando los proyectos que se van a restaurar...
  Todos los proyectos están actualizados para la restauración.

Se han usado los orígenes siguientes:
   https://api.nuget.org/v3/index.json
   C:\Program Files (x86)\Microsoft SDKs\NuGetPackages\

El proyecto "AsistenteIA" especificado no tiene paquetes en desuso en los orígenes actuales.

Resultado: APROBADO
```

Figura 2. S02: sin paquetes obsoletos.

Seguridad · Búsqueda de claves de API en todo el repositorio

```
$ git grep -nIE "sk_[A-Za-z0-9]{10,}|pk_[A-Za-z0-9]{10,}|AIza[0-9A-Za-z_-]{30,}|Bearer [A-Za-z0-9_-]{20,}" -- . ":!docs/evidenci
    as"

(sin resultados)

Resultado: APROBADO · ninguna clave real en el código, la configuración ni la documentación
```

Figura 3. S03: ninguna clave de API en el repositorio.

Seguridad / entrega · bin y obj excluidos del repositorio

```
$ git ls-files -- "*/bin/*" "*/obj/*" && git check-ignore -v AsistenteIA/bin/x AsistenteIA/obj/x

.gitignore:33:[Bb]in/AsistenteIA/bin/x
.gitignore:34:[Oo]bj/AsistenteIA/obj/x

Resultado: APROBADO · git ls-files no lista archivos de bin/ ni obj/; ambas carpetas están en .gitignore
```

Figura 4. S04: bin/ y obj/ ignorados por Git.

Seguridad · Todas las URL de servicios usan HTTPS

```
$ git grep -nE "https?://[a-z]" -- AsistenteIA/Services AsistenteIA/Models AsistenteIA/MauiProgram.cs

AsistenteIA/Models/AiProvider.cs:23:        BaseUrl = "https://gen.pollinations.ai/v1/",
AsistenteIA/Models/AiProvider.cs:25:        KeysUrl = "https://enter.pollinations.ai/keys",
AsistenteIA/Models/AiProvider.cs:34:        BaseUrl = "https://generativelanguage.googleapis.com/v1beta/openai/",
AsistenteIA/Models/AiProvider.cs:36:        KeysUrl = "https://aistudio.google.com/apikey",

Resultado: APROBADO · ninguna URL http:// sin cifrar
```

Figura 5. S05: todas las URL usan HTTPS.

Seguridad · Clave en SecureStorage, campo oculto y sin registro en consola

```
$ git grep -nE "SecureStorage|IsPassword=\"True\"|Debug.WriteLine|Console.Write|ILogger" -- AsistenteIA/Services AsistenteIA/Vie
    ws AsistenteIA/ViewModels

AsistenteIA/Services/ApiKeyService.cs:19:        SecureStorage.Default.SetAsync(KeyName(provider), Sanitize(key));
AsistenteIA/Services/ApiKeyService.cs:23:        string? key = await SecureStorage.Default.GetAsync(KeyName(_settings.Provider))
    ;
AsistenteIA/Services/ApiKeyService.cs:27:    public bool Remove() => SecureStorage.Default.Remove(KeyName(_settings.Provider));
AsistenteIA/Services/ApiKeyService.cs:66:        string? legacy = await SecureStorage.Default.GetAsync(KeyName(AiProvider.Pollin
    ations));
AsistenteIA/Services/ApiKeyService.cs:72:        if (string.IsNullOrWhiteSpace(await SecureStorage.Default.GetAsync(KeyName(owne
    r))))
AsistenteIA/Services/ApiKeyService.cs:74:        SecureStorage.Default.Remove(KeyName(AiProvider.Pollinations));
AsistenteIA/Views/SettingsPage.xaml:28:                  <Entry IsPassword="True" Text="{Binding ApiKeyInput}" Placeholder="Pe
    gue aquí su clave"
AsistenteIA/Views/SettingsPage.xaml:32:                          Text="La clave se guarda cifrada con SecureStorage del sistema
     operativo. Nunca se muestra completa, no se registra en consola y no se incluye en el código ni en el repositorio." />

Resultado: APROBADO · la clave nunca se escribe en consola ni en registros
```

Figura 6. S06: SecureStorage, campo IsPassword y ausencia de registros de la clave.

Protección de la clave en la interfaz

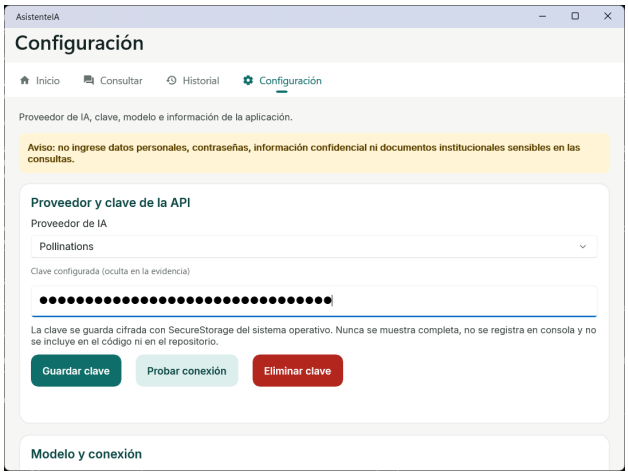


Figura 7. La clave se oculta al escribir.

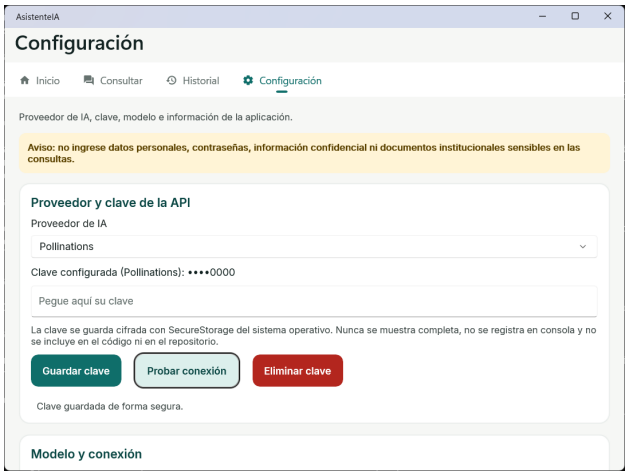


Figura 8. Guardada: solo los 4 últimos caracteres.

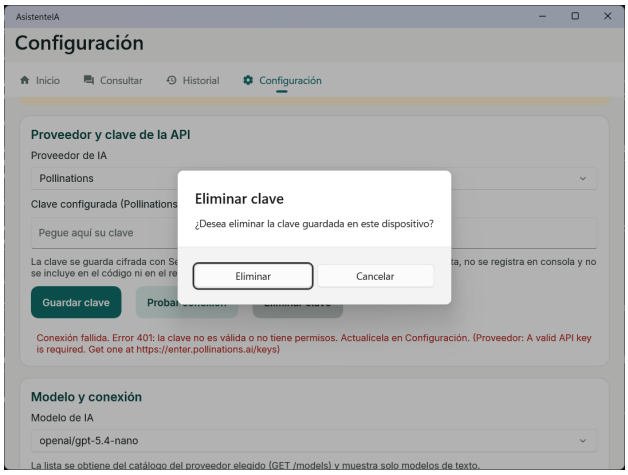


Figura 9. Eliminar clave pide confirmación.

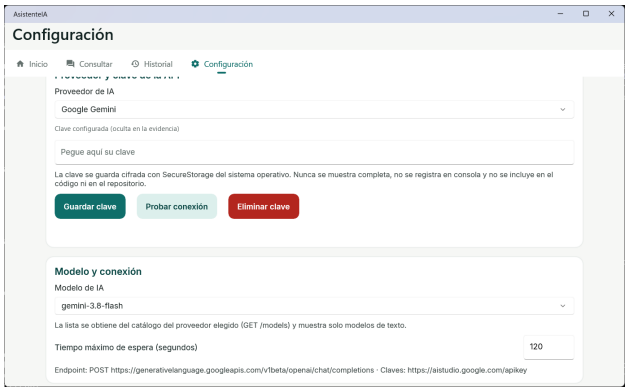


Figura 10. Aviso de privacidad y clave tapada en la evidencia.

6. Controles de privacidad y uso responsable

Riesgo	Control aplicado
Exposición de credenciales	SecureStorage, campo IsPassword, clave enmascarada, sin claves en el código ni en capturas.
Datos personales en el prompt	Aviso visible en Consultar, Configuración e Inicio.
Respuesta incorrecta o inventada	Aviso de verificación en cada respuesta y marca de "verificada" en el detalle.
Difusión de respuestas sin verificar	El texto compartido incluye el aviso de verificación.
Datos del historial	Se guardan solo en el dispositivo (SQLite local).
Registro de errores	errores.log guarda solo la traza técnica, nunca la clave ni el contenido de las consultas.

7. Conclusiones y recomendaciones

- No se encontraron claves expuestas, dependencias vulnerables ni comunicaciones sin cifrar.
- La clave del usuario se guarda cifrada y nunca se muestra completa, en pantalla ni en las evidencias.
- Recomendación: repetir S01 y S02 antes de cada entrega, porque las bases de vulnerabilidades cambian.
- Recomendación: la clave de Pollinations guardada en el equipo de pruebas ya no es válida; actualizarla o eliminarla.